

SEMANA 3



ENGENHARIA REVERSA DE PENSAMENTO (ABUSER STORIES)



ABUSER STORIES



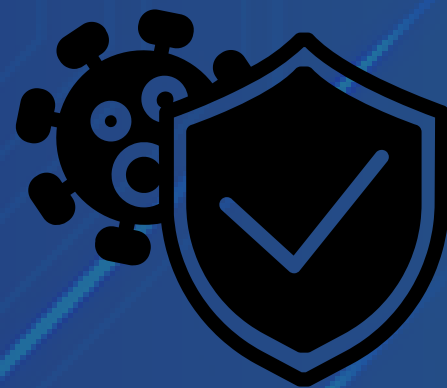
Diferente das "User Stories" (Histórias de Usuário), que focam no que o sistema deve fazer para ajudar o usuário, as Abuser Stories são escritas sob a perspectiva de um invasor

- **Elas descrevem cenários onde alguém tenta utilizar o sistema de forma maliciosa ou prejudicial**



ABUSER STORIES

SEU VALOR:



Elas ajudam a identificar riscos ao valor do negócio e a definir requisitos de segurança logo no início do desenvolvimento

Permitem prever o que pode dar errado e planejar defesas (contramedidas)

CRIANDO ABUSER STORIES



- 1 Workshop de Segurança:** Reúna uma equipe multidisciplinar, incluindo Analistas de Negócios (que conhecem as funções), Pentesters (que pensam como atacantes), Líderes Técnicos e Analistas de QA
- 2 Identificação e Brainstorming:** O Pentester propõe ataques baseados nas funcionalidades que o negócio deseja implementar. Você deve perguntar: "O que pode dar errado aqui?"
- 3 Documentação em Planilha:** Registre os ataques em uma lista contendo um ID único (ex: ABUSE_CASE_001), a descrição do ataque e a funcionalidade impactada
- 4 Avaliação de Risco:** Utilize métodos como DREAD (Dano, Reprodutibilidade, Explorabilidade, Usuários Afetados e Descoberta)
- 5 Definição de Contramedidas:** Para cada história de ataque, a equipe técnica deve propor uma defesa (ex: validar dados, usar criptografia)
- 6 Integração no Desenvolvimento:** As histórias aprovadas tornam-se Critérios de Aceitação nas User Stories (em métodos Ágeis) ou requisitos de segurança (em métodos Tradicionais).

ABUSER STORIES NA PRÁTICA



São usadas em projetos ágeis e tradicionais para garantir que a segurança não seja esquecida e para estimar o esforço necessário para proteger o software...

Portanto para criar qualquer história facilmente, use a fórmula:

"Como um [tipo de atacante], eu quero [ação maliciosa] para [objetivo do dano]"

Exemplos:

"Como um atacante, eu quero tentar descobrir a senha de um usuário várias vezes seguidas até conseguir entrar na conta dele e ver seus dados privados"

Que seria:

"Como um atacante, eu quero realizar um ataque de Brute Force ou Credential Stuffing contra a interface de login para ganhar acesso não autorizado a contas de usuários e/ou explorar a falha **A2:2017-Broken Authentication**"



"Como um hacker, eu quero mudar o preço de um celular no meu carrinho de compras para 1 real, para que eu possa comprar um item caro quase de graça"

Que seria:

"Capacidade de modificar arbitrariamente o preço de um artigo em uma loja online através da manipulação de parâmetros de requisição antes de finalizar o pedido, causando impacto financeiro direto ao negócio"



[Esta presente na lista OWASP TOP 10](#)

ESTUDOS DOS PRINCÍPIOS DE SALTZER E SCHROEDER



Publicados em 1975, são oito princípios fundamentais para o design de sistemas de computação seguros. Eles focam na proteção da informação e na simplicidade dos mecanismos de defesa

PRINCÍPIOS DE SALTZER E SCHROEDER

OS 8 PRINCÍPIOS



- Economia de mecanismo: O design deve ser o mais simples e pequeno possível; quanto menos complexo, mais fácil de proteger.
- Padrão à prova de falhas (Fail-safe defaults): O acesso deve ser baseado em permissão explícita, e não em exclusão. Se algo falhar, o sistema deve "negar acesso" por padrão.
- Mediação completa: Todo acesso a todo objeto deve ser verificado quanto à autoridade.
- Design aberto: A segurança não deve depender do segredo do projeto, mas sim de chaves ou senhas.
- Separação de privilégios: Quando possível, exigir "duas chaves" (duas condições) para liberar um acesso torna o sistema mais robusto.
- Aceitabilidade psicológica: A interface de segurança deve ser fácil de usar para que as pessoas não tentem burlá-la para facilitar o trabalho
- Menor privilégio (Least privilege): Cada programa e cada usuário do sistema deve operar usando o menor conjunto de privilégios necessário para realizar sua tarefa
- Mecanismo menos comum (Least common mechanism): Deve-se minimizar a quantidade de mecanismos que são comuns a mais de um usuário e dos quais todos dependem

[Os oito princípios fundamentais para o design de sistemas seguros de Saltzer e Schroeder, POREM explicados usando Star Wars](#)

PRINCÍPIOS DE SALTZER E SCHROEDER NA PRÁTICA



Durante o início do Ciclo de Vida de Desenvolvimento de Software (SDLC), são usados como um "checklist" durante a fase de arquitetura e design de qualquer software para evitar erros básicos de segurança

Exemplo com Padrão à Prova de Falhas:

“Imagine uma porta eletrônica de um banco. Se o sistema de energia cair ou o software travar, a porta deve permanecer trancada por padrão. É mais seguro ter que usar uma chave manual para abrir do que deixar a porta aberta para qualquer um entrar enquanto o sistema está fora do ar”

Realmente seria:

“As decisões de acesso devem ser baseadas em permissão explícita, e não em exclusão. A situação padrão é a falta de acesso; o mecanismo de proteção identifica apenas as condições específicas sob as quais o acesso é permitido. Se o mecanismo falhar, ele deve falhar negando o acesso (o que é seguro), evitando que um erro de implementação passe despercebido e exponha o sistema”



Exemplo com Menor Privilégio:

“Pense em um usuário criado apenas para fazer cópias de segurança (backup) no computador. Ele não precisa de permissão para instalar jogos ou ler seus e-mails pessoais; ele deve ter acesso apenas aos arquivos que precisa salvar”

Realmente seria:

“Cada módulo (seja um processo, usuário ou programa) deve ser capaz de acessar apenas as informações e recursos necessários para seu propósito legítimo. Isso limita o dano potencial que pode resultar de um acidente, erro ou uso impróprio de privilégios dentro do sistema”



PRINCÍPIO DO MENOR PRIVILÉGIO (POLP)



É o conceito de que cada usuário, programa ou processo deve ter o mínimo de permissões necessárias para realizar sua tarefa, e nada mais...

Ou seja:

Cada módulo ou usuário deve ter apenas o acesso estritamente necessário para sua função específica. Isso limita o "raio de explosão" caso algo seja invadido ou ocorra um erro acidental

- Ajuda a reduzir a "superfície de ataque" e evita o chamado "privilege creep" (quando um usuário acumula acessos de cargos antigos que não usa mais)

PRINCÍPIO DO MENOR PRIVILÉGIO (POLP) NA PRÁTICA



Usado amplamente em gerenciamento de contas de usuário, configuração de bancos de dados e permissões em sistemas de arquivos ou nuvem...

Estratégia eficaz, usando seguintes passos: **Descobrir** (quem tem acesso), **Projetar** (definir quem precisa de quê), **Impor** (aplicar as travas), **Monitorar** e **Otimizar**

Exemplos de casos com PoLP:

“Um usuário comum deve realizar suas tarefas diárias (como navegar na internet ou escrever textos) usando uma conta de usuário padrão. Ele só deve abrir uma conta de administrador protegida por senha quando a situação realmente exigir, como para instalar um novo driver ou alterar configurações críticas do sistema”

Que seria:

“Implementação de Privilégio Zero Permanente (ZSP) ou Acesso Just-in-Time (JIT). Em vez de contas com direitos administrativos ativos o tempo todo, o sistema utiliza o escaneamento de privilégios (bracketing), onde as permissões elevadas são assumidas no último momento possível e descartadas assim que a tarefa termina, reduzindo o tempo de exposição a possíveis ataques”



“Uma conta criada apenas para fazer cópias de segurança (backup) não precisa de permissão para instalar softwares ou ler e-mails pessoais. Ela deve ter direitos apenas para acessar os arquivos que precisam ser salvos e rodar o aplicativo de backup”

Que seria:

“Aplicação de Controle de Acesso Baseado em Funções (RBAC) ou Atributos (ABAC). O sistema define permissões granulares no nível do sistema operacional ou da aplicação, garantindo que a conta de serviço tenha apenas permissões de "leitura" em volumes específicos e "escrita" no destino do backup, sem acesso a outros recursos de rede ou interfaces de gerenciamento”





REFERÊNCIAS

https://cheatsheetseries.owasp.org/cheatsheets/Abuse_Case_Cheat_Sheet.html

<https://www.softdesign.com.br/blog/abuser-stories-voce-ja-ouviu-falar/>

<https://iris.unitn.it/bitstream/11572/251142/1/SPM-fail-safe-v7.pdf>

<https://www.cloudflare.com/pt-br/learning/access-management/principle-of-least-privilege/>

<https://dev.to/owasp/security-in-requirements-phase-33ad>

<https://shostack.org/blog/the-security-principles-of-saltzer-and-schroeder>

Duvidas?